

TSEC Risk & Cyber Advisory LLC

Integrated Cybersecurity, Risk & Compliance Advisory

TSEC-FREE-009

HIPAA Security Rule Checklist

Pre-Assessment Readiness Tool — HIPAA Security Rule Safeguards

45 CFR Parts 160 and 164 (HIPAA Security Rule)

Document ID:	TSEC-FREE-009
Version:	1.0
Date:	June 2026
Classification:	CONFIDENTIAL
Prepared by:	TSEC Risk & Cyber Advisory LLC

www.tsecgrc.com | info@tsecgrc.com

1. Purpose & Applicability

This checklist assesses readiness against the HIPAA Security Rule (45 CFR Part 164). It applies to Covered Entities (CEs) and Business Associates (BAs) that create, receive, maintain, or transmit electronic Protected Health Information (ePHI). Use this checklist in conjunction with a formal HIPAA Risk Analysis per 45 CFR §164.308(a)(1).

2. Administrative Safeguards (§164.308)

§164.308 — Administrative Safeguards		
#	Control / Requirement	Status (✓/X/NA)
1	A formal HIPAA Security Risk Analysis has been conducted and documented.	
2	A Risk Management Plan addresses identified risks to ePHI.	

3	A sanction policy is in place for employees who violate HIPAA requirements.	
4	Information system activity is reviewed through audit logs and reports.	
5	A workforce security program governs authorization and access to ePHI.	
6	Security awareness and training is provided to all workforce members.	
7	A documented Contingency Plan (backup, DR, emergency access) exists.	
8	Business Associate Agreements (BAAs) are in place with all applicable vendors.	
9	An Incident Response and Reporting Policy is documented and tested.	

3. Physical Safeguards (§164.310)

§164.310 — Physical Safeguards		
#	Control / Requirement	Status (✓/X/NA)
1	Facility access controls limit physical access to systems containing ePHI.	
2	Workstation use policies govern who may access ePHI workstations and how.	
3	Workstations with access to ePHI are positioned to prevent unauthorized viewing.	
4	Media disposal procedures ensure ePHI is irrecoverably destroyed.	
5	Hardware and electronic media movement is tracked and documented.	

4. Technical Safeguards (§164.312)

§164.312 — Technical Safeguards		
#	Control / Requirement	Status (✓/X/NA)
1	Unique user identification is assigned to all users accessing ePHI.	
2	Emergency access procedures allow authorized access during system failures.	
3	Automatic logoff is configured for systems accessing ePHI.	
4	ePHI is encrypted at rest where technically feasible.	
5	ePHI is encrypted in transit using TLS 1.2+ or equivalent.	
6	Audit controls are implemented to record access to ePHI.	
7	Integrity controls prevent unauthorized ePHI alteration or destruction.	
8	Transmission security prevents unauthorized access to ePHI in transit.	

5. Organizational Requirements (§164.314)

§164.314 — Organizational & Documentation		
#	Control / Requirement	Status (✓/X/NA)
1	Business Associate Agreements (BAAs) are executed with all applicable third parties.	
2	Policies and procedures are documented, implemented, and maintained.	
3	Documentation is retained for a minimum of 6 years from creation or last effective date.	
4	Policies and procedures are reviewed and updated periodically.	

6. Gap Tracker

CFR Ref	Gap Description	Remediation Action	Owner	Due